



CUERPO SUPERIOR DE SISTEMAS Y TECNOLOGÍAS DE LA INFORMACIÓN DE LA ADMINISTRACIÓN DEL ESTADO

T.79 El cifrado. Algoritmos de cifrado simétricos y asimétricos. La función hash. El notariado.

T.80 y 81 Identificación y firma electrónica. Certificados digitales. Claves privadas, públicas y concertadas. Infraestructura de Clave Pública (PKI)

T.124 La seguridad en las Redes (Técnicas Criptográficas)

Fecha Actualización: 20-06-2025

Índice del tema

1. INTRODUCCIÓN. IMPORTANCIA DE LAS POLÍTICAS DE SEGURIDAD.	3
1.1. EJEMPLOS DE ATAQUES:	3
1.2. LA POLÍTICA DE SEGURIDAD	3
2. EL MARCO DE LA SEGURIDAD DE LA ADMINISTRACIÓN ELECTRÓNICA	4
2.1. NECESIDADES DE SEGURIDAD:	4
2.2. DEBILIDADES DE LOS SISTEMAS BASADOS EN CONTRASEÑAS	4
3. CRIPTOGRAFÍA	5
3.1. ALGORITMOS CRIPTOGRÁFICOS	5
3.1.1 Algoritmos de cifrado clásico	5
3.1.1.1 Cifrados Monoalfabéticos	5
3.1.1.2 Cifrados Polialfabéticos	6
3.1.1.3 Cifrados por Sustitución Homofónica	6
3.1.1.4 Cifrados de Transposición	6
3.1.2 Algoritmos de clave simétrica o privados:	7
3.1.2.1 Funcionamiento del algoritmo DES:	7
3.1.2.2 Modos de funcionamiento Cifrado Simétrico:	7
3.1.2.3 El algoritmo IDEA (International Data Encryption Algorithm)	8
3.1.2.4 El algoritmo Rijndael (AES)	8
3.1.2.5 Descripción del cifrado	8
3.1.3 Criptoanálisis de Algoritmos Simétricos	10
3.1.4 Algoritmos de clave asimétrica o públicos:	10
3.1.4.1 Funcionamiento del algoritmo Diffie-Hellman	11
3.1.4.2 Funcionamiento del algoritmo RSA:	11
3.1.5 Algoritmos de hash:	12
3.1.6 Longitudes de Claves empleadas:	13
4. LA FIRMA ELECTRÓNICA	13
4.1. DESCRIPCIÓN	13
4.2. PROCESO DE FIRMA Y COMPROBACIÓN	14
4.3. SOBRE DIGITAL	15
5. EL CERTIFICADO DIGITAL	15
5.1. ESTÁNDARES	15
5.2. TIPOS DE CERTIFICADOS	15
5.3. GESTIÓN DE LOS CERTIFICADOS	15

6. PKI (PUBLIC KEY INFRASTRUCTURE) 16

6.1. COMPONENTES DE UNA PKI 16

6.2. RELACIONES ENTRE ENTIDADES DE CERTIFICACIÓN 17

6.3. SERVICIOS DE UNA AUTORIDAD DE CERTIFICACIÓN 18

6.3.1 Servicios esenciales: 18

6.3.2 Servicios complementarios: 18

6.3.3 Servicios avanzados: 18

6.4. PRESTADORES DE SERVICIOS DE CERTIFICACIÓN EN ESPAÑA..... 18

6.4.1. La FNMT – RCM: Proyecto CERES (CERTificación ESpañola)..... 18

6.4.1.1. ¿Cómo se obtiene el certificado? 19

6.4.1.2. Tipos de certificados emitidos por la FNMT..... 19

6.4.2. Camerfirma 19

6.4.3. ANCERT 20

7. EJEMPLOS DE PROTOCOLOS SEGUROS..... 20

7.1. SSL (SECURE SOCKETS LAYERS) 20

7.2. SET (DE VISA)..... 20

7.3. 3D SECURE (DE VISA, VERIFIED BY VISA, VBV Ó 3D SSL) 20

8. EJEMPLO DE CERTIFICADO DIGITAL..... 22

1. Introducción. Importancia de las políticas de seguridad.

La Seguridad en términos relativos a las tecnologías de la información ha adquirido progresiva importancia hasta convertirse en uno de los principales factores a tener en cuenta en los procesos de las empresas debido fundamentalmente a factores como: la apertura de las corporaciones a Internet, el incremento exponencial del número de personas conectadas a la Red, utilización de dispositivos ligados a la Red, etc., favoreciendo estos factores la aparición de un caldo de cultivo en el que se multiplican los ataques contra empresas.

1.1. Ejemplos de ataques:

Las medidas aisladas como la instalación de Firewalls o métodos de autenticación en los sistemas corporativos, no constituyen en sí una solución al problema: es necesario considerar la Seguridad como un proceso, una política global que abarca tanto aspectos técnicos como humanos.

Esto es debido a la variada tipología de ataques que una empresa puede recibir, y que pueden clasificarse en:

- **ataques físicos:** inciden en los sistemas físicos (ordenados, conectores, cables, etc..), para mitigarlos se utilizan técnicas de redundancia.
- **ataques sintácticos:** aquéllos que tratan de aprovechar vulnerabilidades de los programas software utilizados en la organización (errores de programación, uso de algoritmos de encriptación de datos débiles o malas implementaciones de algoritmos robustos, etc..) a los cuáles sólo se puede hacer frente mediante actualizaciones de software, parches, etc..
- **ataques semánticos:** los que inciden en el factor humano, el punto más complicado de proteger dentro de una política global de seguridad (explotan la tendencia del ser humano a confiar en terceros y no comprobar la veracidad de las informaciones) y que convierten de forma involuntaria a un usuario "interno" en partícipe de un ataque.

La finalidad de los ataques es muy variada: dañar la imagen de una corporación, buscar la denegación de servicio, obtención de información reservada..etc..

Si a estos aspectos se añade que el software en sí (la herramienta de trabajo habitual en cualquier corporación) – por su creciente complejidad, por la imposibilidad de probar funcionalmente su seguridad, porque los fabricantes no suelen asumir responsabilidad alguna ante fallos, y porque hay siempre formas de hacer cualquier producto inseguro - no puede garantizar la ausencia de fallos en la seguridad, se llega a la conclusión de la necesidad de definir unos procesos de seguridad de carácter global.

El objetivo, por tanto, es establecer una política de seguridad global (teniendo en cuenta que la seguridad total no existe) poniendo énfasis en diseñar esta política de acuerdo a las necesidades de los procesos de negocio de la organización, y, en este sentido, persiguiendo la máxima seguridad posible con el mínimo coste.

1.2. La Política de Seguridad

Una política de seguridad debe ser clara, conocida y asumida por todos los miembros de una organización y estará basada en la concienciación de usuarios, prevención, detección y respuesta ante ataques.

En este sentido existen dos actividades fundamentales:

- **análisis de riesgos:** persigue identificar las amenazas sobre los recursos implicados en los sistemas de información de la empresa, y así estimar el impacto que una seguridad ineficiente puede tener en la organización.
- **gestión de riesgos:** su objetivo es seleccionar e implantar los mecanismos de seguridad adecuados para prevenir, impedir y reducir los riesgos detectados y sus posibles perjuicios. Estos mecanismos de seguridad recogerán las acciones necesarias para reducir el riesgo sobre vulnerabilidades, pudiendo ser éstas preventivas o curativas (reducir el impacto cuando se ha materializado una amenaza).

Su estudio permite conocer las líneas a seguir para implantar una política de seguridad en una organización. Una vez diseñada, es necesario ponerla en práctica y, al margen de aspectos técnicos, para ello es fundamental:

- contar con pleno apoyo y compromiso de la dirección
- promover la cooperación, educación y concienciación de todo el personal
- hacer partícipe de la política a todo el personal, recogiendo sugerencias de mejora y, en general, la realimentación del día a día
- una política de seguridad debe sólida pero que no impida el funcionamiento normal y eficiente de la organización

La Seguridad es un medio para proteger una empresa, corporación, etc.. y nunca un fin en sí mismo.

2. El marco de la seguridad de la Administración electrónica

La revolución de la tecnología de la información, conjuntamente con la de las comunicaciones y el inseparable desarrollo del canal internet, está haciendo cambiar las relaciones entre individuos y organizaciones en todo el mundo, permitiendo la comercialización de productos y servicios en un mercado global → **e-Business**

La Administración Pública no es ajena a ello: la utilización de esos mismos medios, electrónicos, informáticos y telemáticos (EIT) en el entorno administrativo, se ve como una oportunidad de modernización por un lado, y como un medio de acercamiento al ciudadano, por otro. En suma, como medio para alcanzar mayor eficacia y eficiencia. → **e-Administración, e-Gov, Administración electrónica** (varias denominaciones)

e-Business vs Administración Electrónica: mismos medios, distintos objetivos.

- **Objetivo:** El principal cambio respecto a la Administración tradicional es la substitución del formato papel por el formato electrónico, así como la realización telemática de los trámites administrativos, con igual seguridad, validez y confianza.
- **Riesgos:** Este cambio ha provocado la reactualización de ciertas amenazas contra la seguridad de la operación, que en los usos tradicionales estaba resuelta.
- **Necesidades:** Los servicios de seguridad aplicables al comercio basado en documentos en papel y el basado en documentos electrónicos, requieren disponer de funciones análogas: los documentos típicamente contienen firmas y fechas, necesitan protegerse de posibles revelaciones de contenido, falsificación o destrucción, y necesitan ser registrados.

2.1. Necesidades de seguridad:

- El remitente de la transacción: ¿es en realidad quien dice ser? → **Servicios de autenticación y control de acceso.**
- La información recibida, ¿es la misma que fue enviada? → **Servicios de integridad**
- La información enviada, ¿podrá ser espiada por un tercero? → **Servicios de confidencialidad**
- ¿Podrá el remitente negar que la ha enviado, o el destinatario que la ha recibido? → **servicios de no repudio en origen y destino respectivamente**

La probabilidad de amenaza es tanto mayor cuanto más **abierta y mayor es el número de usuarios de la red** por la que viaja la transacción.

2.2. Debilidades de los sistemas basados en contraseñas

La mayoría de los servicios actuales fundamentan su seguridad en la identificación de los participantes a través de un nombre y/o una contraseña (password) → adecuado para una red cerrada con usuarios conocidos de antemano.

Sin embargo, en redes abiertas como internet, no es posible garantizar plenamente la confidencialidad de la información, ni la identidad de los participantes.

Debilidades de los sistemas basados en contraseñas:

- **Poco variables:** Las contraseñas son actualizadas con poca frecuencia
- **Predecibles:** Los usuarios tienden a utilizar contraseñas **sencillas**
Los usuarios suelen utilizar las **mismas** contraseñas para todos los servicios a los que acceden.
- **Almacén vulnerable:** Las contraseñas son almacenadas en una base de datos del sistema
- **Transporte vulnerable:** En casos de acceso remoto las contraseñas viajan en claro por la red
- **Ineficaces:** El ***correo electrónico convencional*** **no** permite garantizar la autenticidad del remitente, ni permite garantizar la confidencialidad ni la integridad.

3. Criptografía

La criptografía es la base de muchas de las herramientas que se utilizan en procesos de seguridad y surgió ante la necesidad de asegurar que un determinado mensaje únicamente iba a poder ser interpretado por aquellas personas a las que iba destinado. → "**Escritura Oculta**"

Conceptos esenciales: (base de la mayoría de algoritmos criptográficos utilizados en la actualidad).

- ♦ **Difusión:** dispersa la redundancia de un texto plano distribuyéndola a lo largo del texto cifrado.
Reparte la influencia de cada bit del mensaje original entre el mensaje cifrado. Trasposición
- ♦ **Confusión:** oculta la relación entre el texto en claro, el texto cifrado y la clave → sustitución.

3.1. Algoritmos criptográficos

Algoritmo criptográfico: función matemática empleada para cifrar y descifrar.

Cifrado: proceso de transformar información de manera que sólo sea inteligible para su destinatario.

Descifrado: proceso por el cual se hace inteligible la información cifrada.

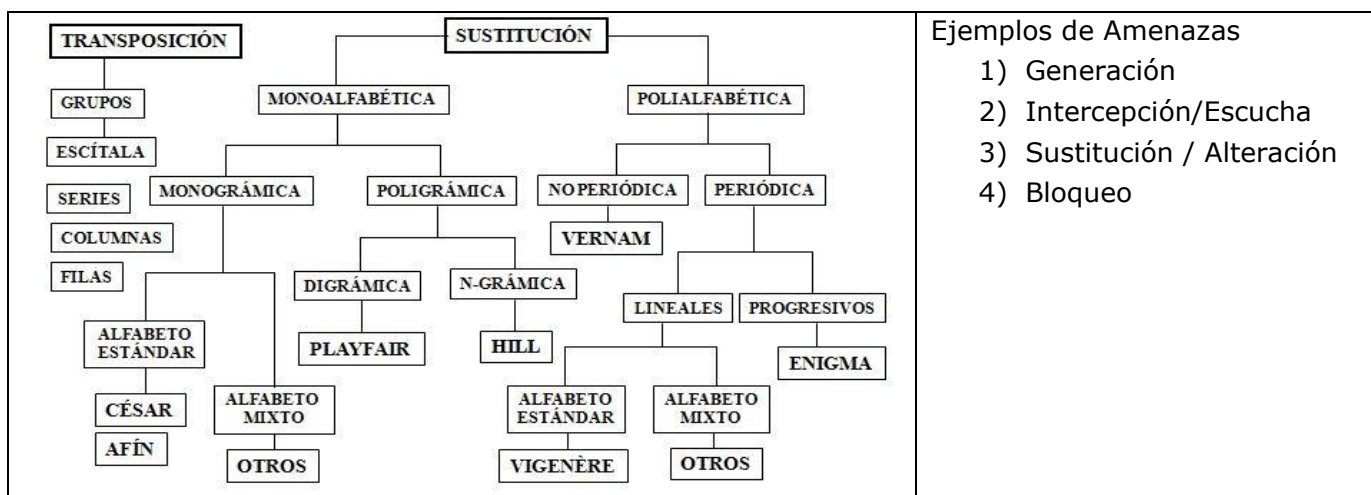
No a la seguridad por oscuridad: Con la mayoría de los métodos actuales de criptografía, la seguridad no se basa en el algoritmo criptográfico, que es ampliamente conocido, sino en un parámetro de dicho algoritmo llamado **clave**, que se emplea para cifrar, descifrar o ambas cosas.

Los principales problemas a solventar en cualquier comunicación electrónica segura, en los que la criptografía va a ser herramienta esencial, son los siguientes:

- ♦ **Autenticación:** proceso por el que se establece la identidad de un software o una persona (básicamente, establecer de forma fehaciente la identidad de los intervinientes en una comunicación electrónica).
- ♦ **Confidencialidad:** proceso que persigue que la información sólo pueda ser accedida por las personas a las que va dirigida o que tienen autorizado el acceso.
- ♦ **Integridad:** cómo lograr que la información no pueda ser alterada durante la comunicación sin que tengamos conocimiento de ello.
- ♦ **No repudio** (en origen y destino): cómo lograr que nadie pueda negar la autoría de los mensajes que ha emitido y negar la recepción y acceso a un mensaje.

La criptografía (base de las distintas soluciones a estos problemas) se divide en **simétrica y asimétrica**.

3.1.1 Algoritmos de cifrado clásico



3.1.1.1 Cifrados Monoalfabéticos

Establecen una correspondencia única para los símbolos en todo el texto.

La correspondencia se mantiene a lo largo de todo el mensaje, sin desordenarlos

Algoritmo de cifrado César (En honor a Julio Cesar)

Es uno de los más simples → Consiste en sumar 3 al número de orden de cada letra.

La transformación criptográfica sería:

$$C = (M + 3) \bmod 26 \text{ (considerando un alfabeto de 26 letras)}$$

Este algoritmo no posee clave: → la transformación siempre es la misma.

Sustitución Afín

Es el caso general del algoritmo de César. Su transformación sería:

$$E(a;b)(M) = (aM + b) \bmod N;$$

a, b enteros menores que el cardinal N del alfabeto, y $\text{mcd}(a;N) = 1$.

La clave de cifrado k viene entonces dada por el par (a; b).

Cifrado Monoalfabético General

Es el caso más general de cifrado monoalfabético → La sustitución es arbitraria,

La clave k es la tabla de sustitución de un símbolo por otro. Existen N! posibles claves.

Criptografía de los Métodos de Cifrado Monoalfabéticos

Son los métodos más simples de criptoanalizar: Las propiedades estadísticas del texto claro se conservan en el criptograma.

Para averiguar la clave: Se emparejan las frecuencias relativas de cada símbolo en el mensaje cifrado con el histograma de frecuencias del idioma (texto en claro) → emparejamiento arbitrario, la Distancia de Unicidad de Shannon:

$$S = H(K)/D = \log_2(N!)/D$$

D es la redundancia del lenguaje empleado en el mensaje original, y

N es el número de símbolos de dicho lenguaje. las N! claves diferentes son equiprobables

En casos más restringidos, como el afín, el criptoanálisis es aún más simple → el emparejamiento de todos los símbolos responde a alguna combinación de coeficientes (a; b).

3.1.1.2 Cifrados Polialfabéticos

La sustitución aplicada a cada carácter varía en función de la posición que ocupe éste dentro del texto claro → aplicación cíclica de n cifrados monoalfabéticos.

Criptografía

Se efectúan "d" análisis estadísticos independientes agrupando los símbolos según la k_i empleada para codificarlos.

"d" se estima buscando la periodicidad de los patrones comunes que aparecen en el texto cifrado.

Se necesitan al menos d veces más cantidad de texto que con métodos monoalfabéticos.

3.1.1.3 Cifrados por Sustitución Homofónica

Buscan paliar la sensibilidad frente a ataques basados en el estudio de frecuencias de símbolos. Emplean un alfabeto de salida con más símbolos que el alfabeto de entrada.

Tiene demasiados inconvenientes para ser útil en la práctica:

- Se necesita un alfabeto de salida mayor que el de entrada
- Hace falta conocer la distribución estadística a priori de los símbolos en el texto claro

3.1.1.4 Cifrados de Transposición

Cambia el orden de los símbolos dentro del texto.

Escitalo: un bastón cilíndrico con un radio particular y una tira de piel que se enrollaba alrededor.

- Se coloca el texto en una tabla de n columnas
- Texto cifrado: los símbolos de las columnas concatenados ordenados de arriba abajo.
- La clave k se compondría del número n junto con el orden en el que se deben leer las columnas.

Por ejemplo: Cifrar el texto "El perro de San Roque no tiene rabo", con $n = 5$ y la permutación $\{3,2,5,1,4\}$ como clave → "osonealr r irednu eoere et p aqonb"

1	2	3	4	5
e	l		p	e
r	r	o		d
e		s	a	n
	r	o	q	u
e		n	o	
t	i	e	n	e
	r	a	b	o

Criptografía

Estudio estadístico sobre la frecuencia de aparición de pares y tripletas de símbolos.

3.1.2 Algoritmos de clave simétrica o privados:

- 1 sola clave para cifrar y descifrar y que deben conocer las dos partes que intervienen en la relación telemática
- Claves necesarias para **n** usuarios: **$n(n-1) / 2$**
- Son sencillos y más fácilmente implementables en hardware
- Son rápidos y eficientes
- Se puede distinguir:
 - criptografía simétrica de bloques (ej.: algoritmo DES)
 - criptografía simétrica de flujos
 - criptografía simétrica de resumen (funciones hash, como MD5 y SHA-1).
- Ejemplos Bloque:
 - DES** (Data Encryption Standard). Muy débil (64bits, 56bits efectivos). Se rompe en tiempo real.
 - IDEA** (International Data Encryption Algorithm)
 - TDES** (Triple DES). Intento por robustecer DES.
 - Rijndael** → **AES** (Advanced Encryption Standard)
 - BLOWFISH, TWOFISH** (su evolución, de Bruce **Schneier**). Finalista
 - Bloque:** RC-2, RC-5, RC-6, CAST, GOST, SAFER, SKIPJACK, **Camelia, Kasumi**
- **Flujo:**
 - SEAL, WAKE, Rabbit (128), SNOW 3G (128). Inseguros: RC4, A5/1 y A5/2 GSM, E0 (Bluetooth)
- Presentan varios **problemas** operativos:
 - la necesidad de que cada pareja de interlocutores (emisor y receptor) compartan una misma clave, dificulta la gestión de las claves
 - No podemos garantizar completamente el no repudio (debido también a la compartición de las claves)
 - Confidencialidad y autenticación sólo podrán garantizarse mientras la clave simétrica se mantenga en secreto entre cada par de interlocutores → peligra en grandes comunidades como Internet.

3.1.2.1 Funcionamiento del algoritmo DES:

DES (Data Encryption Standard) es el algoritmo más extendido (junto con sus variantes posteriores), estándar oficial de EEUU para cifrado simétrico, y tiene su origen en 1972 (algoritmo LUCIFER, desarrollado por IBM a principios de los setenta) dentro de un proyecto promovido por el NIST (National Institute of Standards and Technology) con el objetivo de obtener métodos que protegiesen los ordenadores y las comunicaciones, debiendo tener las siguientes características: alto grado de seguridad, sencillez de implementación, eficiencia, y utilización de un algoritmo público.

DES: es una red de **Feistel**, toma como entrada bloques de 64 bits del mensaje original y cifra independientemente cada uno de ellos sometiéndolos a 16 interacciones con una clave de 56 bits (56 bits+ 8 bits de paridad = 64 bits); Operaciones: permutaciones, operaciones XOR (or-exclusiva) y la alternancia de los bits de la clave que se utilizan en cada iteración del proceso (se seleccionan 48 bits de la clave de los 56 disponibles cada vez).

Hasta la fecha, DES no ha podido romperse mediante criptoanálisis, pero sí mediante fuerza bruta (1998). Por ello, han surgido variantes posteriores como triple-DES → aplicación por tres veces de DES, tal y como se describe:

- 1) encriptar en sentido directo el bloque B0 con una clave K0 → bloque B1
- 2) encriptar en sentido inverso (desencriptar) el bloque B1 con una clave K1 → bloque B2
- 3) encriptar en sentido directo el bloque B2 con una clave K2 → bloque B3 final
- 4) repetir el proceso para el resto de bloques del mensaje original

Clave de $56 \times 3 = 168$ bits efectivos: por el momento no ha podido romperse. Robustez 112Bits

TDES 2EDE: Long clave 112 Bits efectivos, Robustez 80 bits.

Ataque: **Meet-in-the-middle**: Basado en compromiso Espacio-Tiempo (Cifrar-Descifrar a la vez)

3.1.2.2 Modos de funcionamiento Cifrado Simétrico:

Modo **ECB** (Electronic Codebook): Subdivide la cadena a codificar en bloques que se cifran independientemente.

Ventajas	Permite codificar los bloques independientemente de su orden. Adecuado para codificar BBDD o ficheros → acceso aleatorio. Es resistente a errores de comunicación/transmisión.
Desventajas	Sufre problemas de patrones repetitivos, del texto en claro que se trasladan al texto cifrado → ataque estadístico Sustitución de bloques: altera mensajes incluso desconociendo la clave y/o el algoritmo

Modo CBC (Cipher Book Chaining Mode): incorpora un mecanismo de realimentación en el cifrado por bloques. Esto significa que la codificación de bloques anteriores condiciona la codificación del actual. Para cifrar el primer bloque → vector de inicialización (V.I.) → conocido por ambos interlocutores. No resulta apto para descifrar bloques individuales del mensaje, necesario descodificar todos los anteriores.

Modo PCBC (Propagating cipher-block chaining)

El modo propagating cipher-block chaining fue diseñado para que pequeños cambios en el texto cifrado se propagasen más que en el modo CBC.

Modo CFB (Cipher-Feedback): Cada bloque cifrado y combinado, XOR, con el siguiente bloque del mensaje original. Se sincroniza automáticamente a partir del segundo bloque consecutivo que llegue de forma correcta ante propagación de errores. Longitud de los bloques del mensaje menor o igual que la longitud de bloque del algoritmo de cifrado → cifrar bit por bit ó byte por byte

Modo OFB (Output-Feedback). Genera una secuencia de bloques totalmente independiente del mensaje, que luego se combina con este último bit a bit. Cifrado de flujo

Counter (CTR)

Genera el siguiente bloque en el flujo de claves cifrando valores sucesivos de un contador.

CFB, OFB y CTR convierten una unidad de cifrado por bloques en una unidad de flujo de cifrado.

3.1.2.3 El algoritmo IDEA (International Data Encryption Algorithm)

Es bastante más joven que DES.1992.

Trabaja con bloques de 64 bits de longitud y emplea una clave de 128 bits.

Usa el mismo algoritmo tanto para cifrar como para descifrar.

No presenta claves débiles.

Su longitud de clave hace imposible en la práctica un ataque por la fuerza bruta. (de momento)

Se basa en los conceptos de confusión y difusión → operaciones elementales:

- _ XOR.
- _ Suma módulo 216.
- _ Producto módulo 216 + 1.

3.1.2.4 El algoritmo Rijndael (AES)

Rijndael: acrónimo formado por los nombres de sus autores, los belgas Joan Daemen y Vincent Rijmen.

Adoptado en octubre de 2000 por el NIST (National Institute for Standards and Technology) como nuevo Estándar Avanzado de Cifrado (AES) para su empleo en aplicaciones criptográficas no militares como **FIPS PUB 197**

Venció en la final al TWOFISH

Se transformó en un estándar efectivo el 26 de mayo de 2002

El proceso de selección, revisión y estudio, tanto de este algoritmo como de los restantes candidatos se ha efectuado de forma pública y abierta → digno de la confianza de todos.

Cifrado por bloques, diseñado para manejar **longitudes de clave** y bloque variables (AES Solo Bloques 128Bits).

Longitudes de clave: AES especifica: **128-192**(opcional)-**256** bits. **Rijndael:** 128, 160, 192, 224 y 256 bits.

Realiza varias de sus operaciones internas a nivel de byte, el resto en términos de registros de 32-64 bits.

Sus ventajas son su gran seguridad, sencillez y velocidad de cifrado.

AES puede ser usado como:

- algoritmo de bloques (block cipher),
- algoritmo de flujos (stream cipher)
- función resumen (hash function)
- generador de números pseudoaleatorios

Al contrario que su predecesor DES, Rijndael es una **red de sustitución-permutación**, no una red de Feistel. AES es rápido tanto en software como en hardware, es relativamente fácil de implementar, y requiere poca memoria. Como nuevo estándar de cifrado, se está utilizando actualmente a gran escala.

AES opera en una matriz de 4×4 bytes, llamada **state** (algunas versiones de Rijndael con un tamaño de bloque mayor tienen columnas adicionales en el state).

Rijndael soporta claves que sea múltiplo de 32 bits, con un mínimo de 128 bits y un máximo de 256 bits.

Rijndael soporta Tamaños de bloque de 128, 160, 192, 224 y 256 bits. AES solo especifica bloques de 128 bits.

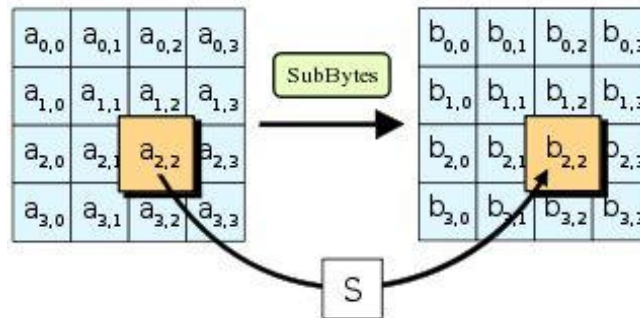
3.1.2.5 Descripción del cifrado

Etapas iniciales:

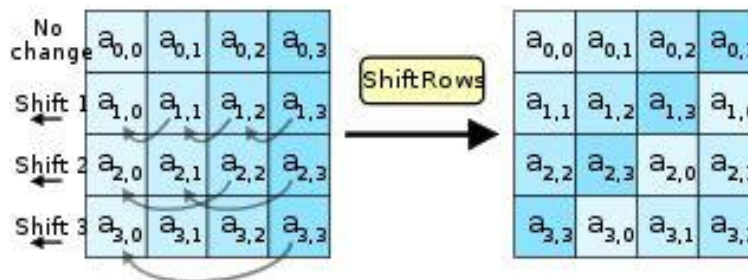
1.AddRoundKey: **Cálculo de las subclaves**

Rondas:

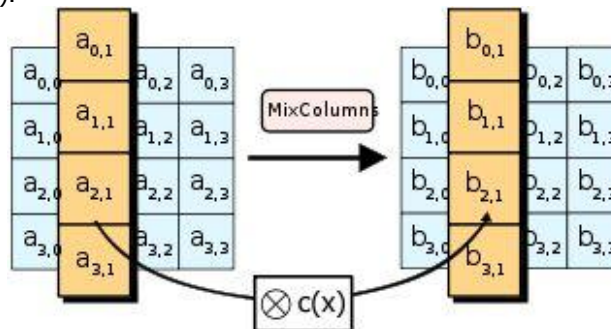
1.SubBytes — **Substitución de bits:** en este paso se realiza una sustitución no lineal donde cada byte es reemplazado con otro de acuerdo a una tabla de búsqueda. Esta operación provee la no linealidad en el cifrado.



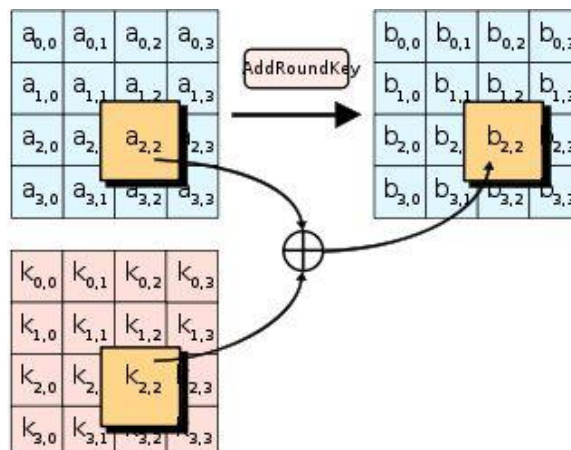
2.ShiftRows — **Desplazamiento de Filas:** en este paso se realiza una transposición donde cada fila del «state» es rotada de manera cíclica hacia la izquierda un número determinado de veces. El número de lugares que cada byte es rotado difiere para cada fila.



3.MixColumns — **Cambio de Columnas:** operación de mezclado que opera en las columnas del «state», combinando los cuatro bytes en cada columna usando una transformación lineal: multiplicada por un polinomio constante $c(x)$.



4.AddRoundKey — **Cálculo de las subclaves:** cada byte del «state» es combinado con un byte de la subclave «round» usando la operación XOR ($\oplus$). Cada clave «round» se deriva de la clave de cifrado usando una iteración de la clave.



Etapas finales:

1. SubBytes
2. ShiftRows: **Cambio de Columnas**
3. AddRoundKey: **Cálculo de las subclaves**

Optimización del cifrado: En sistemas de 32 bits o de mayor tamaño de palabra, es posible acelerar la ejecución de este algoritmo mediante la conversión de las transformaciones SubBytes, ShiftRows y MixColumn en tablas. Se tienen cuatro tablas de 256 entradas de 32 bits que utilizan un total de 4 kilobytes (4096 bytes) de memoria, un Kb cada tabla. De esta manera, una ronda del algoritmo consiste en 16 búsquedas en una tabla seguida de 16 operaciones XOR de 32 bits en el paso AddRoundKey. Si el tamaño de 4 kilobytes de la tabla es demasiado grande para una plataforma determinada, la operación de búsqueda en la tabla se puede realizar mediante una sola tabla de 256 entradas de 32 bits mediante el uso de rotaciones circulares.

3.1.3 Criptoanálisis de Algoritmos Simétricos

Se podría decir que el criptoanálisis se comenzó a estudiar seriamente con la aparición de DES.

Se dice que existen estructuras extrañas, puertas traseras

Representan mecanismos más eficientes que la fuerza bruta para criptoanalizar un mensaje.

Los métodos parten de disponer de grandes cantidades de pares texto claro-texto cifrado.

Criptoanálisis Diferencial (Biham y Shamir (1990))

Permite efectuar un ataque de texto claro más eficiente que la fuerza bruta.

Se basa en el estudio de los pares de criptogramas que surgen cuando se codifican dos textos claros con diferencias particulares, analizando la evolución de dichas diferencias a lo largo de las rondas de DES.

Se toman dos mensajes cualesquiera (incluso aleatorios) idénticos salvo en un número concreto de bits. Usando las diferencias entre textos cifrados, se asignan probabilidades a las diferentes claves de cifrado. Conforme tenemos más y más pares, una de las claves aparece como la más probable → la clave buscada

Criptoanálisis Lineal

Descubierto por Mitsuru Matsui, basa su funcionamiento en tomar algunos bits del texto claro y efectuar una operación XOR entre ellos, tomar algunos del texto cifrado y hacerles lo mismo, y finalmente hacer un XOR de los dos resultados anteriores, obteniendo un único bit.

Efectuando esa operación a una gran cantidad de pares de texto claro y criptograma diferentes podemos ver si se obtienen más ceros o más unos.

Si el algoritmo criptográfico en cuestión es vulnerable a este tipo de ataque, existirán combinaciones de bits que den lugar a un sesgo significativo.

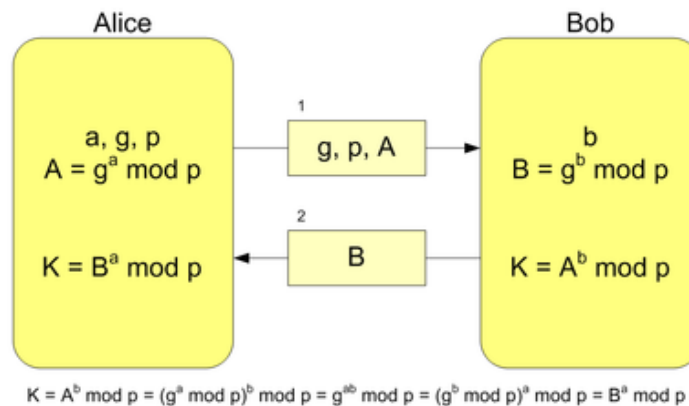
Esta propiedad nos va a permitir poder asignar mayor probabilidad a unas claves sobre otras.

3.1.4 Algoritmos de clave asimétrica o públicos:

- **2 claves:** una pública y otra privada, **matemáticamente relacionadas**.
- Debe ser imposible obtener una clave a partir de la otra.
- La clave **pública** está **accesible** a cualquiera
- La clave **privada** es de uso **restringido** para su propietario
- Los mensajes cifrados con la clave pública sólo pueden ser descifrados por la clave privada asociada → **garantía de confidencialidad**
- Los mensajes cifrados con la clave privada sólo pueden ser descifrados con la clave pública (que todos conocen) → esta característica es el fundamento de la **firma digital**
- Claves necesarias para **n** usuarios: **2*n** → O(N)
- Existen tres tipos diferentes de algoritmos matemáticos:
 - Factorización entera: RSA y RW (de Rabin Williams), EL GAMAL.
 - Logaritmo discreto: DH (Diffie-Hellman), DSA (Digital Signature Alg.-David Kravitz), DSS.
 - Logaritmo discreto elíptico: DHE (Diffie-Hellman elíptico) y DSAE (DSA elíptico).
- Ejemplos:
 - RSA (Rivest-Shamir-Adelman)** (aritmética modular: factorización de grandes números)
 - DSA: (Logaritmo Discreto)-
 - Diffie-Hellman : (Logaritmo Discreto)
 - DSS: (Logaritmo Discreto)
 - Massey-Omura: **exponenciación en un Campo de Galois GF(2n)**
 - EL GAMAL (usa aritmética modular, Logaritmo Discreto)
 - CURVAS ELÍPTICAS (usa curvas elípticas)
 - Rabin : (calcular raíces cuadradas módulo un número compuesto)
 - Merkle-Hellman (Inseguro)

- Los algoritmos de clave asimétrica permiten una gestión racional de las claves pero son menos eficientes que los simétricos → uso en la práctica de una combinación de ambos: cifrado a través un algoritmo simétrico, con una clave que se utiliza sólo durante una sesión (**clave de sesión**). Los interlocutores intercambian esta clave de sesión mediante algoritmos asimétricos.
- **Garantizan:** la **autenticación**, la **confidencialidad**, el **no repudio de emisor** y la **integridad**.
- Ejemplo de aplicación: **SSL** (Secure Socket Layer o Capa de conexiones seguras). Es un protocolo para cifrar el tráfico de transacciones en una red entre dos aplicaciones remotas, donde en una primera parte de la comunicación (el hand-shake) las partes se identifican mutuamente mediante algoritmos de clave pública y negocian el algoritmo de clave simétrica y la clave de sesión que utilizarán en el resto de la comunicación.
- **Las aplicaciones fundamentales de la criptografía asimétrica son:**
 - el intercambio seguro de claves privadas (para codificación simétrica – confidencialidad)
 - la firma electrónica.

3.1.4.1. Funcionamiento del algoritmo Diffie-Hellman



Diffie-Hellman fijo: los parámetros públicos de DH se envían en un certificado (generado por CA). Requiere certificado con estos parámetros.

Diffie-Hellman efímero: la clave pública DH se envía firmada con la clave privada del emisor (RSA o DSS). Permite intercambiar claves privadas efímeras (un solo uso). Es el más seguro de los métodos DH. Requiere certificado.

Diffie-Hellman anónimo: se envían los parámetros DH sin autenticar. Es vulnerable al ataque de hombre en medio.

3.1.4.2. Funcionamiento del algoritmo RSA:

Los algoritmos utilizados se basan en la supuesta imposibilidad de resolver los problemas que plantean de una forma computacionalmente eficiente (al menos mientras no se descubran algoritmos más rápidos para abordar estos problemas). El algoritmo más común es el RSA, basado en el problema matemático que representa la factorización de un entero n "grande" en dos números primos p y q de, aproximadamente la misma longitud.

El proceso es el siguiente:

- 1) Cada usuario genera un número n (distinto para cada uno de ellos) producto de dos números primos p y q de similar longitud y que no estén cerca el uno del otro. $n = pq$
- 2) n será la clave pública de cada usuario y p y q serán la base (mediante ciertas operaciones matemáticas) de la clave privada que cada usuario almacenará en secreto.
- 3) Si A quiere enviar un mensaje a B, entonces obtendrá la clave pública de B (que debe estar a disposición de quien lo requiera) y con ella cifrará el mensaje
- 4) Cuando B quiera leer el mensaje, lo podrá decodificar con su clave privada, la única capaz de hacerlo.

La seguridad del algoritmo queda determinada por el "tamaño del número n " o, lo que es lo mismo, la longitud de las claves utilizadas. Se considera que un tamaño de 1024 bits es suficiente para actividades de ámbito personal y de 2048 bits en adelante para actividades comerciales.

$$e \cdot d \mod(\lambda(n)) = 1 \quad c = m^e \mod n$$

$$\lambda(n) = (p-1)(q-1) \quad m = c^d \mod n.$$

3.1.5 Algoritmos de hash:

Es un algoritmo **unidireccional**, ligado a la firma digital, que crea una representación digital o huella de un mensaje. Su resultado es de tamaño fijo y generalmente mucho menor que el del mensaje original y único para éste, de bajo costo computacional y uniforme/equiprobable.

La aplicación de un algoritmo Hash sobre unos datos produce el llamado '**resumen**', '**huella digital**' o '**digest**' de esos datos.

Características más significativas:

- **Resistencia a la preimagen:** No se pueden obtener los datos originales a partir del "hash" → función unidireccional : computacionalmente imposible encontrar un $X \rightarrow \text{hash}(X) = Y$
- **Resistencia a la colisión:** No es posible encontrar una secuencia de datos con el mismo "hash": imposible encontrar dos mensajes x y x' tales que $\text{hash}(x) = \text{hash}(x')$ (Débil Vs Fuerte)
- **Resistencia a la casi-colisión:** Es difícil encontrar dos mensajes x y x' , tales que $\text{hash}(x)$ y $\text{hash}(x')$ difieran solamente en unos pocos bits.
- **Funciones con colisiones de hash parciales:** Son funciones en las que invirtiendo cierto coste en procesamiento de CPU y memoria es posible encontrar en tiempos razonables dos entradas que produzcan resultados en los que sus bits se parezcan en cierto grado. Por ejemplo, que se parezcan en un porcentaje de bits, o más comúnmente que sean iguales los n -bits más significativos.
- **Sistema de prueba de trabajo:** "POW" (Proof-Of-Work system), es un sistema que, para evitar comportamientos indeseados (por ejemplo ataques de denegación de servicio o spam), requiere que el cliente del servicio realice algún tipo de trabajo que tenga cierto coste y que es verificado fácilmente en la parte del servidor. Normalmente el trabajo consiste en realizar un cómputo en el ordenador del cliente. La característica clave de la estrategia es su asimetría: El trabajo debe ser moderadamente difícil (pero factible) por el lado del cliente, pero fácil de verificar por el lado del servidor.
- **Resistencia a las preimágenes parciales:** Una función hash tiene resistencia a preimágenes parciales (Partial-preimage resistance) si es difícil encontrar una parte de la preimagen de un valor hash incluso conociendo el resto de la preimagen. Es decir, se debe recurrir a la fuerza bruta: si se desconocen t bits de la preimagen, se deben realizar en promedio 2^{n-t} operaciones de hash para encontrarlo. A una función hash resistente a preimágenes parciales también se le dice que es localmente de un solo sentido (del inglés local one-wayness).
- **Uso:**
 - Se utiliza para **verificar la integridad**.
 - Conocido el algoritmo de hash utilizado, el receptor puede recrear la huella digital del mensaje recibido y comparar esta huella con la enviada (adjunta al mensaje y de forma segura) por el emisor. Si coinciden el mensaje no ha sido manipulado durante la transmisión.
 - MAC: Message Authentication Code: Aplicación del principio de Horton
 - * El uso de valores MAC para autenticar provee cierta seguridad pero no es la panacea. Por ejemplo podría haber un ataque que consistiera en interceptar el mensaje y el valor MAC para poder reutilizarlo para autenticarse.
 - * El principio de Horton establece que se debe autenticar el significado del mensaje, y no el código del mensaje. Aplicando el principio a autenticación de mensaje con MAC, deberíamos autenticar no sólo el valor MAC, sino también cierta información que sea usada para formar un valor MAC que no sea ambiguo. Por ejemplo, puede ser buena idea incorporar algún tipo de sello de tiempo cuando calculo el valor MAC (por ejemplo concatenándolo al mensaje)
 - MDC: Modification/ Manipulation Detection Code , por ejemplo en CSV
 - OTP: One Time Passwd
- * **Algoritmos:** SHA2, SHA3, SHA-1 (Secure Hash Algorithm), SSHA-1 (Salted Secure Hash Algorithm) de la NSA, bastante seguro, MD5 (Message Digest 5), Vulnerable¹, RIPEMD-160. Europeo de libre acceso.

¹ El 17 de Agosto de 2004 Xiaoyun Wang, Dengguo Feng, Xuejia Lai y Hongbo Yu (*Shandong University* en China) descubrieron colisiones de hash para MD5. Su ataque sólo llevó una hora de cálculo con un clúster IBM P690.

3.1.6 Longitudes de Claves empleadas:

Algoritmo	ALGORITMO	Longitud de Clave (bits)	OBSERVACIONES
Simétricos	IDEA	128	(recomen. ≥ 128 bits)
	DES	64	Efectivos, sólo 56
	3DES	168	Con 56 efectivos del DES, efectivos 112
	RC5	Variable	>56bits prohibido exportarlo fuera de USA
	Rijndael (AES)	128, 192 ó 256	Longitud variable
Asimétricos Clave Pública	Camellia (Japón)	Long Clave 128, 192 o 256 Tamaño bloque 128	Prestaciones y seguridad equivalente a AES. Soportado en TLS/SSL
	Diffie-Hellman	Variable	(recomen. ≥ 1024)
	RSA	Variable	$\geq 1024/2048$
	Curvas Elípticas	Variable	160
Huella - HASH	RIPEMD-160	160	Otras posibles 128, 256 y 320
	MD5	128	Débil
	SHA-1	160	Teóricamente débil, se recomienda SHA2
	SHA-2	+224	SHA224, SHA256, SHA384, y SHA512
	SHA-3	Mismos que SHA2	Diseño Independiente de SHA2 ante futuros ataques

≈ El NIST contempla funciones de SHA de mayor tamaño (p.e. SHA-512, 512 bits). Expertos como Bruce Schneier abogan por buscar una nueva función hash estandarizada que permita sustituir a SHA-1. Los nombres que se mencionan al respecto son Tiger, de los creadores de Serpent, y WHIRLPOOL, de los creadores de AES.

SHA-3 es un subconjunto de la familia primitiva criptográfica más amplio Keccak (<https://keccak.team/keccak.html>) Publicado por NIST el 5 de agosto de 2015.

Algoritmos		
Simétricos	Bloque	Flujo
	FEAL-N, RC2, Khufu, Khafre, IDEA, SAFER, Blowfish, RC5, RC6 , CAST, SHARK, SQUARE, MISTY, ICE, Skipjack, Rainbow, SMS4, GOST, Mars, Serpent, 3-Way, AES, Camellia , CAST-128/256, CMEA, DEAL, DEX-X, GDES, KASUMI , KHAZAD, LOKI89/91, Lucifer, MAGENTA, MARS, MMB	RC4, SEAL, WAKE , A5/1, A5/2, Chameleon, FISH, Helix, ISAAC, Panama, Pike, SOBER, SOBER-128
Asimétricos	RSA, DSA, DH Diffie-Hellman, DSS, Massey-Omura, EL GAMAL, Curvas Elípticas...	
Firma-hash	MD, SHA, SHA1, SHA2, SHA3, RIPDEM160, SSHA, GOST, WHIRLPOOL, Tiger, Haval, Senefru,...	
Compresión	LZ-77, LZ-78, LZW, ZIP, WPEG, HUFFMAN, RLE, etc..	

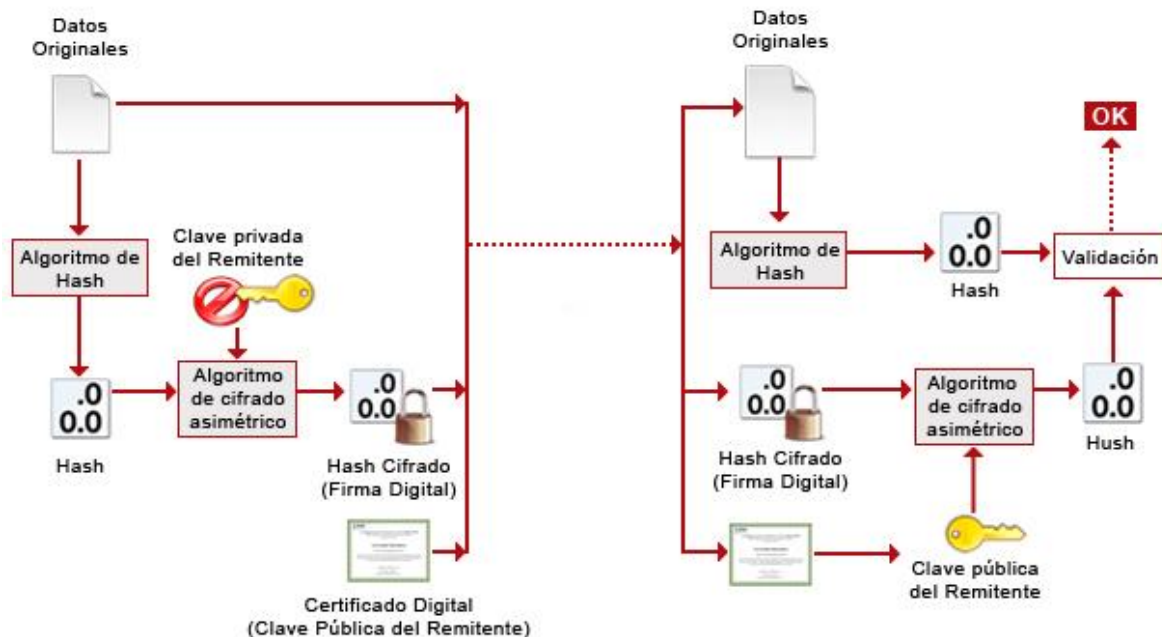
4. La Firma electrónica

4.1. Descripción

- * **Definición legal:** "es el conjunto de datos en forma electrónica, consignados junto a otros o asociados con ellos, que pueden ser utilizados como medio de **identificación** del firmante y la **integridad** de los datos
- * **Físicamente:** Es una serie de bits que se calculan con la clave privada del firmante y un resumen del documento
- * Es un procedimiento de transmisión telemática de actos declarativos de voluntad, con la misma validez que la firma manuscrita, en el caso de firma electrónica reconocida
- * Cada usuario tiene una clave **privada propia**, de uso exclusivo, y una **clave pública accesible** por terceros
- * **Puede garantizar:**
 - **Autenticidad:** Identifica al remitente de un mensaje de manera fidedigna (si puedo usar su clave pública...)

- **Integridad:** El resumen o huella digital del documento verifica que el mensaje no ha sido manipulado
- **No repudio:** El emisor del mensaje no puede negar su existencia, porque se ha usado su clave privada
- * La **clave privada** puede ser almacenada en el propio ordenador o en una tarjeta con chip → siempre queda bajo el **control exclusivo de su titular**, por lo que tiene la garantía de que nadie más que él puede hacer uso de ella.
- * La clave privada puede (mejor debe) estar protegida con un **PIN** (clave personal)
- * **Problema:** No puedo asegurar que la clave pública sea de quien dice ser su dueño -> necesito confianza mediante una tercera parte de confianza

4.2. Proceso de firma y comprobación



Esquema del proceso de firma digital y comprobación de un mensaje:

- 1 El emisor **calcula un resumen** del mensaje a firmar, llamado hash o digest.
- 2 El emisor, con su clave privada y únicamente el hash obtenido, **genera la Firma Digital**, que queda asociada al mensaje.
- 3 El emisor **envía** al destinatario el documento y la firma digital por cualquier medio.
- 4 El receptor, con la clave pública (obtenida del certificado digital del emisor) **comprueba** que la **firma digital** es correcta y obtiene el **hash** original enviado. (Previamente puede comprobar con las listas de revocación de certificados (CRLs) publicadas por la CA que el certificado del emisor no ha sido revocado)
- 5 El receptor **genera un nuevo resumen** o huella digital del documento recibido con el mismo algoritmo de hash que utilizó el emisor.
- 6 **Comprobación:** El documento es válido (generado por quien dice haberlo generado y con el contenido inalterado) si se cumple que:
 - El certificado digital del emisor es válido
 - La firma digital del documento se descifra con la clave pública del emisor (compruebo la autenticidad y el no repudio)
 - La huella digital de la firma digital enviada y la generada coinciden (compruebo la integridad)

4.3. Sobre Digital

- * Resuelve la **confidencialidad**, mediante cifrado simétrico de TODO el documento
- * Usando la **clave pública del receptor** se cifra la **clave simétrica** pseudoaleatoria utilizada
- * **Sobre digital** = documento cifrado sim. + clave simétrica cifrada asimétricamente

5. El Certificado Digital

- * **Definición:** El CERTIFICADO es "la certificación electrónica que vincula unos datos de verificación de firma a un signatario y confirma su identidad.
- * Es un documento electrónico que **acredita la identidad** del usuario
- * Se puede utilizar para cifrar mensajes que sólo el usuario del certificado podrá leer
- * Los CERTIFICADOS son el sopORTE para la clave PUBLICA

La entrada en vigor del REGLAMENTO (UE) No 910/2014 DEL PARLAMENTO EUROPEO Y DEL CONSEJO (23 de julio de 2014) relativo a la identificación electrónica y los servicios de confianza para las transacciones electrónicas en el mercado interior deroga la Directiva 1999/93/CE y se deja de hablar de "prestadores de Servicios de Certificación" para hablar de "P.S. de Confianza" TSP por sus siglas en Inglés. (Trusted Serv. Prov)

5.1. Estándares

X.509 v3: estándar de certificados digitales propuesto por la ITU-T (International Telecommunications Union). Define la estructura y representación de un certificado y los distintos elementos que contiene:

Clave pública del titular del certificado (y otros datos relativos a dicha clave, como algoritmo empleado, función hash...)

Comienzo y fin del periodo de validez del certificado

Número de serie del certificado (código único por entidad certificadora)

El nombre de la autoridad de certificación

Firma digital de la autoridad certificadora

Extensiones: información adicional para diversos propósitos (por ejemplo delimitar su uso: para verificar firmas, para cifrar, para ambas operaciones)

PKCS (Public Key Cryptography Standards): conjunto de estándares para la implementación de un sistema de criptografía de clave pública desarrollado por RSA Laboratories.

PKCS#1: Corresponde al algoritmo RSA

PKCS#3: Corresponde al algoritmo Diffie-Hellman

PKCS#5: Cifrado con clave privada

PKCS#6 y #9: Formato extendido del Certificado

PKCS#7: Formato del Sobre Digital (intercambio de mensajes cifrados o firmados) usado en S/MIME

PKCS#8: Corresponde a la sintaxis de la clave privada.

PKCS#10: Petición de certificación (formato del precertificado): sintaxis para las peticiones de certificados.

PKCS#11 y #15: La especificación de un interfaz de acceso a dispositivos que almacenan información y funciones criptográficas.

PKCS #11 - Cryptographic Token Interface Standard.: Especifica una API, llamada Cryptoki, por medio de la cual los dispositivos que contienen información criptográfica realizan funciones criptográficas.

PKCS #12 - Personal Information Exchange Syntax Standard. Especifica un formato portable para almacenar o transportar las claves privadas de un usuario, los certificados

5.2. Tipos de certificados

Certificados personales o de usuario-cliente (Persona física)

Certificados de servidor (ej: servidores WEB seguros a través de SSL)

Certificados de autoridad de certificación o de P.S. de Confianza (TSP)

Certificados para la firma de código (sw libre de virus, autenticidad del sw, certifica al desarrollador)

Certificados de Componente SW

5.3. Gestión de los certificados

La gestión de los certificados es llevada a cabo por las Entidades de Certificación • (ej: FNMT - RCM = Fábrica Nacional de Moneda y Timbre – Real Casa de la Moneda)

Obligaciones:

Emisión de certificados

Facilitar el acceso público al directorio

Mantener listas de certificados revocados

Publicar la 'Declaración de Prácticas de Certificación'

6. PKI (Public Key Infrastructure)

Una infraestructura de clave pública es una estructura de seguridad basada en sistemas criptográficos de clave pública.

Se denomina "Infraestructura de Firma Digital" al conjunto de leyes, normativa legal complementaria, obligaciones legales, hardware, software, bases de datos, redes, estándares tecnológicos y procedimientos de seguridad que permiten que distintas entidades (individuos u organizaciones) se identifiquen entre sí de manera segura al realizar transacciones en redes

Una PKI determina:

- que entidades entran a formar parte del sistema de certificación y el papel que juegan
- que normas se deben seguir para operar dentro del sistema
- cómo se codifica, transmite y publica la información digital y cual será ésta
- y sobre todo cómo se gestionan las claves y los certificados.

6.1. Componentes de una PKI

Autoridad de certificación:

Es una autoridad de reconocido prestigio (tercera parte de confianza) que da fe de que una clave pública pertenece realmente al sujeto que la posee.

Se encarga de generar los certificados digitales firmándolos con su clave privada.

Para poder leer los certificados es necesario tener la clave pública de la autoridad de certificación (denominado también certificado raíz)

Ejemplos de entidades de certificación: Verisign, Thawte, Entrust, Ancert, ipsca, FNMT

Funciones:

- Emitir los certificados
- Generar la información sobre la revocación de los certificados (CRLs = Certificate revocation list) y firmar dichas listas
- Mantener una BD con los certificados emitidos y según política de la entidad de las claves privadas de cifrado. Nunca las de firma.
- Definir la política de certificación (relaciones con las AR's, admisión de subscriptores)

Autoridad de registro:

Es una entidad autorizada por la autoridad de certificación para auxiliarla en el procedimiento de "dar fe" de que los requisitos que un sujeto tiene que satisfacer para que se le emita un certificado sean satisfechos mediante un procedimiento establecido.

Normalmente este procedimiento consiste en que el sujeto pruebe su identidad.

Funciones	Recibir solicitudes y mantener un registro de las mismas en una BD Recibir solicitudes de revocación y renovación de certificados Publicación de los certificados y de las listas de certificados revocados generados por la AC <u>Generación de informes y de avisos de expiración de certificados</u>
------------------	---

Autoridad de Validación:

Una Autoridad de Validación (VA) es un componente de una PKI que proporciona información del estado de los certificados emitidos por otras Autoridades de manera on-line. Su misión es realizar la consulta de todas las CRLs necesarias para saber el estado del certificado en cuestión, para ello se pueden utilizar varios mecanismos más o menos fiables.

○ ***¿Qué servicios ofrece una VA?***

Una Autoridad de Validación (VA) puede realizar dos tipos de servicios de validación:

- Descarga de CRLs emitidas por Autoridades de Certificación. El cliente de la VA puede descargarse las CRLs y consultarlas manualmente.
- OCSP (On-line Certification Status Protocol). El cliente de la VA puede realizar consultas sobre el estado de un certificado en concreto.

○ ***¿Dónde se puede utilizar una VA?***

Una VA se puede utilizar dentro de cualquier PKI que necesite consultar el estado de un certificado en el momento actual. Basar este conocimiento sólo en CRLs es complicado, ya que la aplicación puede tener un CRL que esté obsoleta → se haya emitido una nueva CRL antes del tiempo de nueva emisión que la primera indica → Importante conocer la política de Publicación de CRLs definida en la DPC del Prestador.

○ ***¿Puede una VA comunicarse con otras VAs?***

Una Autoridad de Validación, además de consultar a las correspondientes CAs, puede consultar a su vez a otras VAs para satisfacer la petición de validación que le ha llegado o simplemente, emitir una respuesta con el valor de "desconocido" en el campo de estado del certificado. Es decir, si se lanza una consulta sobre una VA y no tiene información para responder, puede tratar de consultar otras VAs para dar una respuesta válida.

○ **¿Qué información consulta una VA para construir una respuesta de validación?**

Una Autoridad de Validación en una PKI puede manejar las CRLs de muchas CAs, ahí reside su principal virtud: es un componente de la PKI que centraliza la consulta de estado de certificados para todos los usuarios de todas las CAs de las que posee CRLs. Además, una VA puede dialogar con otras VAs, esto conlleva a que una determinada VA pueda saber el estado de miles de certificados, pertenecientes a una gran cantidad de CAs distintas.

○ **¿Dónde se encuentra la información a consultar por una VA?**

Existen varias soluciones para almacenar la información (CRLs) que consulta una A. de Validación:

- Buscar en las bases de datos de los emisores de certificados.
- Aceptar CRLs de los emisores de certificados.
- Acceder a un Directorio X.500.

○ **Estados de Respuesta de un certificado**

Los estados de una respuesta del estado de un certificado son:

- Desconocido:** La Autoridad de Validación no da respuesta de validación para ese emisor.
- Revocado:** Actualmente el certificado está revocado por los motivos que indica.
- Válido:** significa que el certificado no está revocado.

○ **¿Qué es OCSP?**

La **RFC-6960** (RFC2560 y RFC 5912 obsoletas) normaliza el protocolo OCSP (On-line Certification Status Protocol), que define la información necesaria para preguntar por el estado de un certificado, siendo necesario por un lado algo que identifique unívocamente al certificado en cuestión (número de serie) y por otro, algo que identifique **unívocamente a su emisor**; → varias soluciones. La RFC propone utilizar el **hash** o resumen de **la clave pública de la entidad emisora** y el hash o resumen del **nombre del emisor del certificado**. Con esto se construye una petición en formato OCSP firmada o sin firmar, que se envía a la Autoridad de Validación correspondiente.

RFC 8954: **Online Certificate Status Protocol (OCSP) Nonce Extension**

Atendiendo a la manera de realizar peticiones de consulta de estado de los certificados, el protocolo **OCSP soporta la consulta de certificados de diferentes emisores dentro de una misma petición OCSP**. Esto elimina la necesidad de tener que consultar varias CRLs para conocer el estado de los certificados de diferentes emisores.

○ **¿Cuáles son los protocolos que necesita 'conocer' una VA?**

Como mínimo 2 protocolos distintos: uno para poder acceder al directorio donde se almacenan las CRL a consultar, por ejemplo **LDAP**; y otro para poder responder a una petición de validación de un certificado cuyo emisor puede ser o bien un usuario o bien otra VA, por ejemplo **OCSP**.

Repositorio de certificados (CRL: Certificate Revocation List):

- Repositorio de certificados de clave pública con su estado. Se utiliza el directorio X.500 con acceso LDAP (Lightweight Directory Access Protocol)
- Lista de certificados que han sido revocados por petición del propietario o por iniciativa de la CA emisora.
- Sirve para poder validar que un certificado aún es vigente → tiene validez.
- Cuando un usuario recibe un documento firmado, debe consultar si el certificado que contiene la clave pública para verificar la firma, está vigente o no.

Usuarios ;-)

6.2. Relaciones entre entidades de certificación

- **Certificación cruzada:** Certificado digital que se utiliza para el establecimiento de relaciones de confianza entre 2 Autoridades de Certificación: Cada CA firma el certificado de la otra CA otorgándose de esta forma la confianza bilateral.
Navegar en la cadena de confianza = lista de validaciones de certificados cruzados por la que se ha de "navegar" desde la clave de la CA del usuario origen hasta verificar la clave de la CA del usuario de destino.
- **Modelo jerárquico:** se definen dos tipos de Autoridades de certificación (raíz y subordinadas)

La diferencia estriba en que toda CA subordinada debe obtener su certificado de otra CA (raíz o subordinada). La CA raíz autofirma su certificado denominándose por ello "certificado raíz" → necesaria confianza en la CA raíz.

6.3. ***Servicios de un Prestador de Servicios de Confianza***

6.3.1 **Servicios esenciales:**

- Generación y gestión de claves criptográficas.
- Emisión, revocación, suspensión y renovación de certificados de clave pública.
- Registro de usuarios mediante el que se acredita la identidad, y cualquiera otra circunstancia personal del titular que sea significativa en función del propio fin del certificado.
- Servicios de directorio:
- Publicación de certificados de clave pública en un directorio de acceso público.
- Publicación de listas de revocación en un directorio de acceso público.
- Registro de eventos significativos relacionados con su propia actividad y la de los usuarios del sistema.
- Publicación de políticas y normas técnicas, así como información administrativa relacionadas con los servicios ofrecidos.

6.3.2 **Servicios complementarios:**

- Fabricación y distribución de dispositivos seguros de creación y verificación de firma electrónica, y servicios relacionados, incluyendo almacenamiento de claves y certificados.
- Servicio de atención a usuarios.
- Servicios de verificación de firma digital.
- Servicio de replicación del contenido del directorio de acceso público en directorios externos.

6.3.3 **Servicios avanzados:**

- Archivo y recuperación de claves utilizadas como soporte para el cifrado de documentos y transacciones EIT.
- Servicios de fechado digital. Constancia de fecha y hora de las transacciones EIT.
- Emisión de certificados de atributos, según la recomendación X.509 de la UIT-T (Norma internacional ISO/CEI 9594-8).
- Servicios de confirmación de envío, entrega y recepción de los mensajes intercambiados entre dos partes.
- Certificación de contenido, garantizando la identidad del signatario, la integridad de su contenido y la conservación de documentos EIT.

6.4. ***Prestadores de Servicios de Certificación en España***

La lista completa puede consultarse en la Sede del MINETUR:

<https://sedeaplicaciones.minetur.gob.es/Prestadores/>

6.4.1. **La FNMT – RCM: Proyecto CERES (CERTificación ESpañola)**

"El proyecto CERES (Certificación Española), liderado por la FNMT-RCM, establece una **Entidad Pública de Certificación**, que permita **autenticar** y garantizar la **confidencialidad** de las comunicaciones entre ciudadanos, empresas u otras instituciones y Administraciones Públicas a través de las redes abiertas de comunicación".

Se inicia en 1996 con la formación de un equipo técnico y un equipo jurídico para la elaboración de un estudio de viabilidad y el Plan Director, que dio como resultado la aprobación del marco legal inicial y el desarrollo de la infraestructura piloto.

En 1998 se iniciaron las aplicaciones piloto.

En 1999 la Agencia Estatal de la Administración Tributaria (AEAT) da a los ciudadanos la posibilidad de presentar la renta 1998 y pago de IVA, retenciones a cuenta y declaraciones IRPF para PYMES a través de los certificados emitidos por la FNMT – RCM (CERES)

En la actualidad existen más de 8.739.5140 certificados activos, la mayor parte de ciudadanos que poseen un certificado que puede ser utilizado para su comunicación con cualquiera de los Organismos que hayan firmado un Convenio con la FNMT –RCM

Servicios **básicos**

- ✓ Emisión de certificados de uso general para su uso con las AA.PP.
- ✓ Emisión de certificados para firma del software

Servicios Como **autoridad de registro**:

- ✓ Registro de emisión (alta)
- ✓ Registro de revocación (baja)

Servicios **avanzados**

- ✓ Certificación temporal (**timestamping**)
- ✓ Conocida como TSA o time stamping authorities
 - Vinculan un instante de tiempo a un documento electrónico mediante la firma electrónica.
 - Aseguran la existencia o el contenido del documento en el instante referenciado.
- ✓ Certificación de contenido
- ✓ Confirmación de envío, entrega y recepción de documentos en sistemas de mensajería (mensajería segura)
- ✓ Certificados de atributos

6.4.1.1. ¿Cómo se obtiene el certificado?

- 1.- El usuario se conecta a la web de la FNMT
<https://www.sede.fnmt.gob.es/certificados/persona-fisica>
- 2.- Solicita un Certificado de Usuario
- 3.- Genera su par de claves en el navegador de su equipo. Obtiene el número de solicitud.
 - Se transmite la **clave pública** y NIF
 - Se registra la petición
- 4.- El usuario acude a la **oficina de acreditación** (ante funcionario público acreditado)
 - Se verifica la identidad
 - Se registran sus datos y su número de solicitud
- 5.- El usuario se conecta a la FNMT y **descarga** su certificado
 - El usuario ya puede acceder a los servicios personalizados de la Administración

6.4.1.2. Tipos de certificados emitidos por la FNMT

FNMT Certificado de persona física (antiguo Clase 2 CA software)

FNMT Certificado de Usuario en tarjeta criptográfica (antiguo Clase 2 CA en Tarjeta Criptográfica)

Registro presencial

Claves generadas por el usuario en la tarjeta

Un sólo par de claves para firma y cifrado

Longitud mínima sin límites

Software de gestión de certificados comercial

Certificado de Representante

La FNMT-RCM emite tres tipos de certificados de representante **cualificados** de acuerdo al Reglamento (UE) N° 910/2014, de 23 de julio de 2014, relativo a la identificación electrónica y los servicios de confianza para las transacciones electrónicas en el mercado interior.

Para Administrador Único o Solidario

Para Persona Jurídica

Para Entidad sin Personalidad Jurídica

Certificados para las AAPP, conforme a la Ley 40/2015 la FNMT-RCM:

Certificado de firma electrónica del personal al servicio de la Administración Pública
(**Certificado de empleado público**)

También ofrecen un servicio de **Certificado de Firma Centralizada**

Certificado de Sede electrónica en el ámbito de la Administración (**Componente**)

Certificado de Sello electrónico en el ámbito de la Administración (**Componente**)

Certificados de componente:

Certificados de servidor SSL/TLS, wildcard y SAN multidominio

Certificado de sello de entidad

Certificados de sede y sello para la Administración Pública

6.4.2. Camerfirma

Autoridad de certificación de las Cámaras de Comercio Españolas

Creada en 1999 por el Consejo Superior de Cámaras, pero actualmente es una S.A.

Orientada al sector empresarial pero también ofrece servicios a las AAPP.

Servicios:

- Certificados Personales de Empresa (con o sin poderes)
- Certificados de Servidor
- Servicios de desarrollo de PKI

- Consultoría y Outsourcing

web: www.camerfirma.es

6.4.3. ANCERT

Agencia Notarial de Certificación. (Antiguo FESTE - Fundación para el Estudio de la Seguridad en las Telecomunicaciones)

Dirigida por: Consejo General del Notariado, Consejo General de la Abogacía y la Universidad de Zaragoza
Orientada al sector jurídico y fiscal (comunicaciones intranotariales)

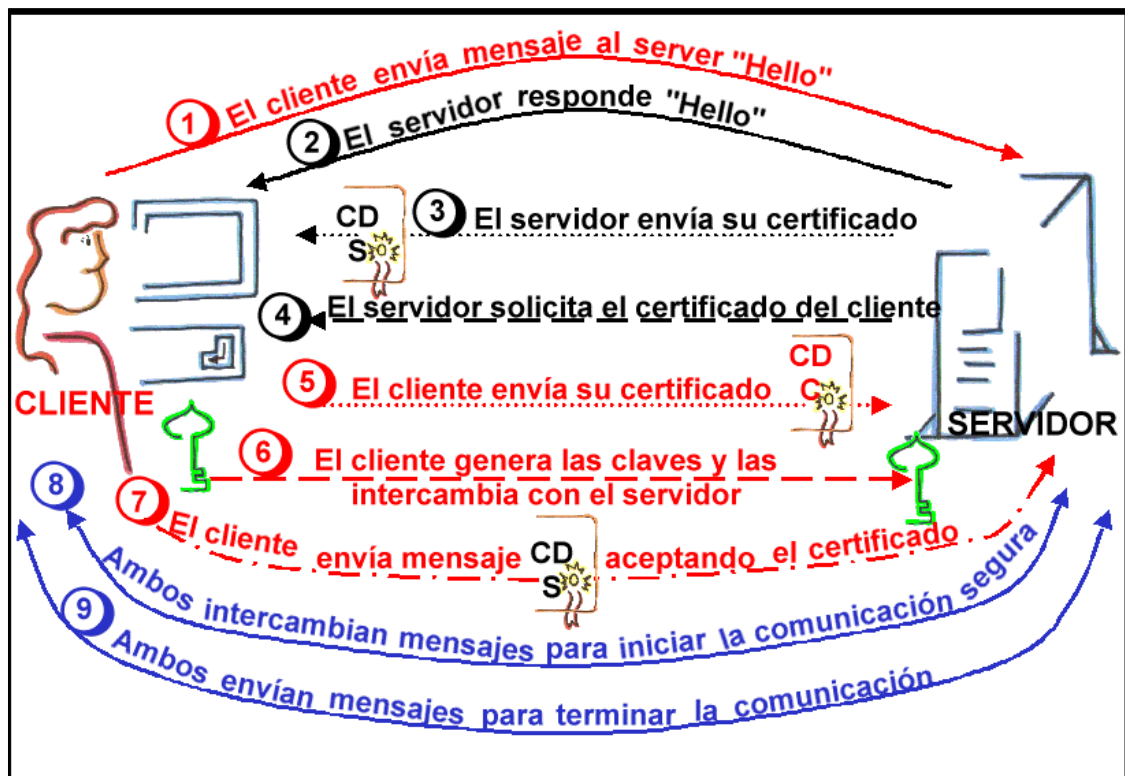
Servicios:

- Certificados Notariales, con identificación y registro ante notario
- Certificados de Servidor Web seguro
- Certificado Corporativo (tanto para corporaciones de derecho privado como público)

web: www.ancert.com

7. Ejemplos de Protocolos seguros

7.1. SSL (Secure Sockets Layers)



7.2. SET (de Visa)

- Complejo y costoso protocolo de comercio electrónico
- Muy seguro
- Poco extendido

7.3. 3D Secure (de Visa, Verified By Visa, VbV ó 3D SSL)

- Es el sucesor de SET
- 3D es "3 Domains": dominios Emisor, Adquiriente y de Intercambio
- Protege al vendedor y al comprador: Verifica la identidad del titular de la tarjeta y del vendedor, mediante un registro previo
- Usa un pin adicional o smartcard para proteger el uso de la tarjeta e identificar al titular

- Sencillo y más económico → te llaman al móvil e introduces tu PIN
- Ahora compatible con Mastercard (MasterCard SecureCode)

8. Ejemplo de certificado digital

Nombre del certificado

NOMBRE: FERNANDO - APELLIDOS: FERNANDEZ FERNANDEZ - NIF 0___4624X

NOMBRE FERNANDEZ FERNANDEZ FERNANDO - NIF 0___4624X

NIF 0___4624X- NOMBRE FERNANDO FERNANDEZ FERNANDEZ

NOMBRE FERNANDO FERNANDEZ FERNANDEZ

FNMT

500051413

ES

Emisor

FNMT

FNMT Clase 2 CA

ES

Detalles

Versión de certificado: 3

Número de serie: 1013927338

No válido antes de: May 16 15:39:06 2003 GMT

No válido después de: May 16 16:09:06 2005 GMT

Huella Digital: E4 10 CF 25 E2 5E E7 FB 82 03 80 4E 68 1D 44 40

Llave algorítmica pública: rsaEncryption

Public-Key (1024 bit):

Módulo:

00: A9 77 41 8F F3 AE 2B 62 A8 19 BF E3 50 33 29 3B
10: 5E 6E 6B 3D EC 16 16 62 42 51 4C CC D2 7B F2 42
20: 8F 4B 5C BE 72 4E 7F 0A B0 7A CF AF 49 8D 28 FF
30: D2 BC 71 6C 63 64 E2 34 7A F5 4F 82 D9 75 48 93
40: E3 F4 07 A3 58 D1 FA 20 10 9A A9 02 0E 6E CD 90
50: C0 95 0A 48 50 2D 0C 2A 52 C2 49 DA 4D 82 D9 06
60: 8F EB A3 4C B4 BB F2 D8 81 A0 DE 56 E1 87 BC BB
70: 47 A2 96 20 19 6B 0B 81 FD D0 D6 07 23 0B 40 B9

Exponente:

01 00 01

Llave algorítmica pública: sha1WithRSAEncryption

00: 3C B7 0F A5 70 BC B6 DF 33 7C 31 5C 45 14 A4 7D
10: 26 35 DC A7 85 AC 32 39 8B 2E 23 8F 73 85 24 95
20: CE F5 1D 35 00 34 B3 45 94 51 B3 4E 55 87 30 FF
30: 7D 80 2A 3F F5 C1 89 BC 07 32 90 6B 19 A0 25 F6
40: 72 B6 E5 F9 8A D4 C5 CE 4C B1 9C 40 68 02 23 FA
50: 84 76 EF 12 C8 91 6A EB 16 17 65 EE 7F C1 1C 18
60: D5 97 43 18 02 B6 B9 F1 0C 88 98 F1 EF 73 A0 4B
70: F7 93 BA 3B 27 AA E9 94 CB 64 70 5B 54 4F 5B 61

Extensiones:

X509v3 Key Usage: Digital Signature, Key Encipherment

X509v3 Private Key Usage Period: Not Before: May 16 15:39:06 2003 GMT, Not After: May 16 16:09:06 2005 GMT

Netscape Cert Type: SSL Client, S/MIME

X509v3 Subject Alternative Name: email:FLO@TELECINCO.COM,
DirName:/1.3.6.1.4.1.5734.1.4=03524624X/1.3.6.1.4.1.5734.1.3=fernandez/1.3.6.1.4.1.5734.1.2=fernandez/1.3.6.1.4.1.5734.1.1=florentino

X509v3 CRL Distribution Points:

DirName:/C=ES/O=FNMT/OU=FNMT Clase 2 CA/CN=CRL878

X509v3 Authority Key Identifier:

keyid:40:9A:76:44:97:74:07:C4:AC:14:CB:1E:8D:4F:3A:45:7C:30:D7:61

X509v3 Subject Key Identifier:

6C:85:0B:92:98:36:8C:B7:D8:2F:58:D2:68:65:97:EC:0F:A8:67:7C

X509v3 Basic Constraints: CA:FALSE

ID de extensión de objeto desconocida 1 2 840 113533 7 65 0: 0..V5.0....

